

CS-2.1 Enable Code Scanning

Status: Draft

Control Objective

- Ensure that the company's people, processes, and technology systems are prepared to perform secure software development.
- Protecting all components of the company's software from tampering and unauthorized access.
- Producing well-secured software with minimal security vulnerabilities in its releases.
- Detecting potential security vulnerabilities before they are released to production systems.
- Identifying residual vulnerabilities in the company's software releases and responding appropriately to resolve those vulnerabilities and prevent similar ones from occurring in the future.

Control Validation

- Software applications written in languages compatible with the company's approved SAST, SCA, and Secrets scanners must be scanned with these tools before software is released.
- Software applications that have web APIs or webpages must be scanned with the company's approved DAST scanner before software is released to production.
- Additional scanning tools such as IAST and IaC scanners should be used when appropriate.
- Code scanning tools should be used in the pre-production environments, ideally in Development or UAT.
- Software developers using standard code editing tools (ex: JetBrains IntelliJ IDEA, Visual Studio Code, Eclipse) must use associated code scanning plugins (ex: Snyk Plugins, Veracode Plugins) to scan their code while they are developing it.
 - This provides the tightest "feedback loop" within the SDLC and gives developers immediate feedback on potential vulnerabilities, as opposed to running scans post-commit or post-deploy.
- Discovered vulnerabilities must be tracked and development teams must fix them as resources and time permits, also considering the SLAs for vulnerabilities.